Part 2: Identify every access path

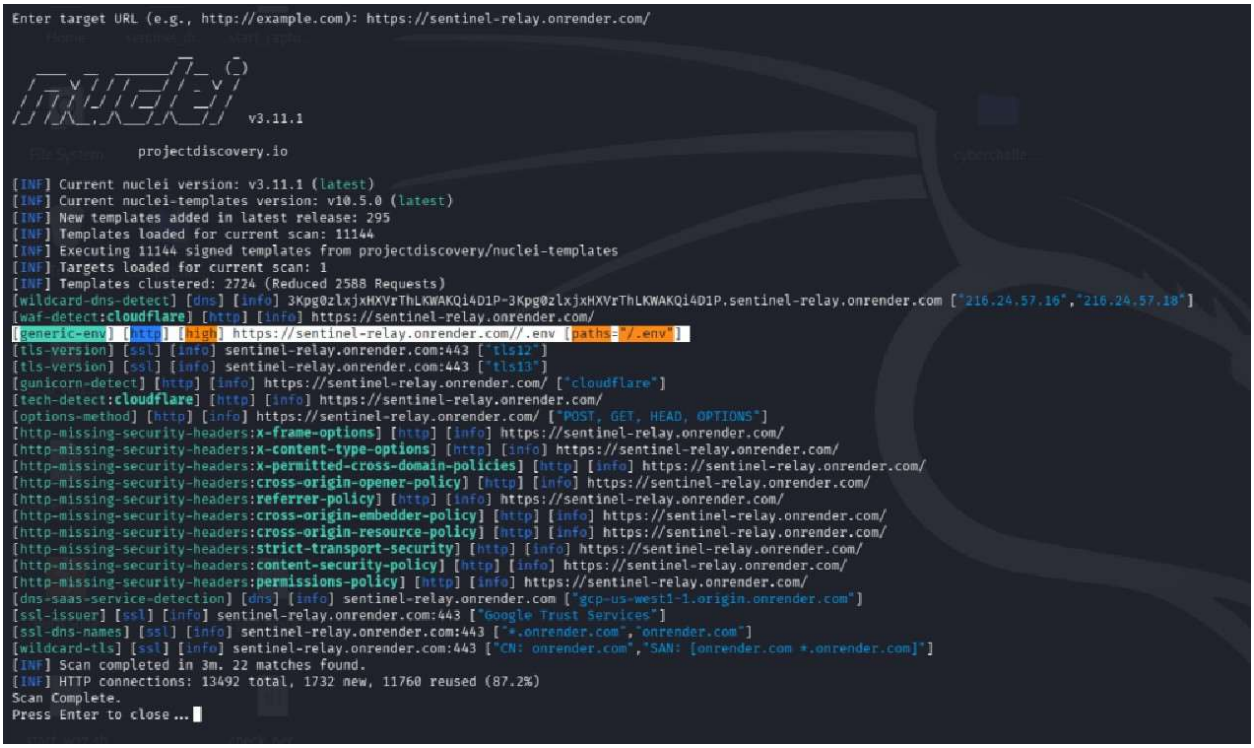
This challenge uses installed forensic tools to identify vulnerabilities and then exploit them.

For this challenge, you are going to construct a flag that is broken into two parts. The first part comes from running the vulnerability scan on our ground station's website.

If you haven't already, copy and paste that curl command from the challenge page into your Linux terminal to install Nuclei alongside its templates and create a desktop shortcut for ease of use in case you need this tool for another challenge.

```
curl -sL
https://raw.githubusercontent.com/holder77/Viceroy_Phantom_Grid_Prep/main/Module_2_Access/neclei_setup.sh | bash
```

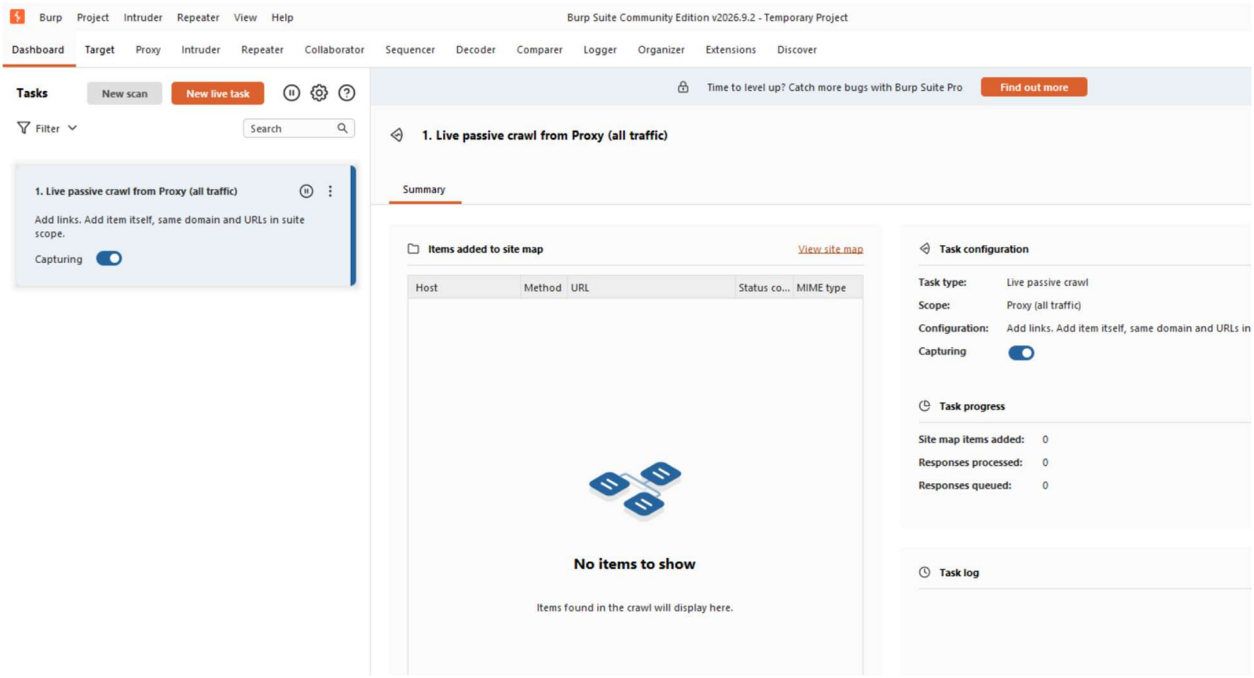
After that, you can double-click that desktop shortcut, and you should be prompted to enter the URL of the website you want to scan. (Yes, I know I have a typo in the name of my script from GitHub; it's too late, and we're gonna do this live just copy and paste that curl command and let it rip!)



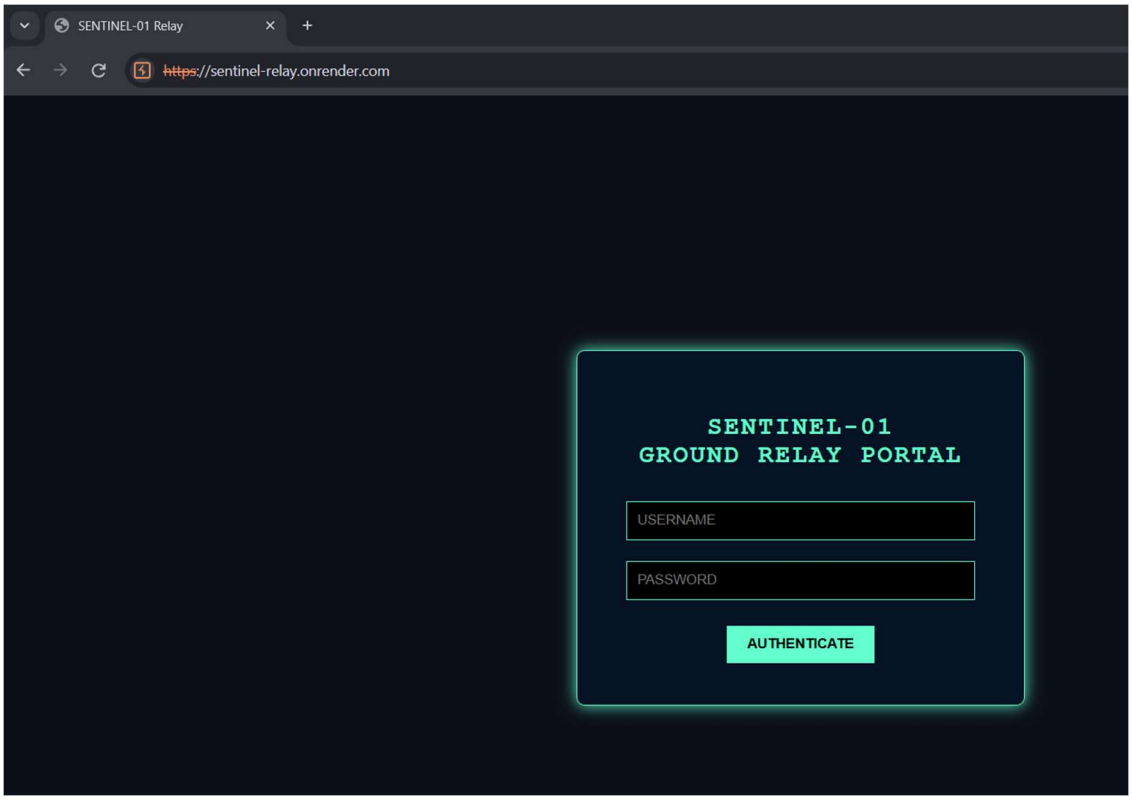
It's going to take about 5 minutes or so, but the service is going to fully scan our web application against known threats. We found one high-rated vulnerability: the .env file isn't secured, and you can access it. Go to that first link to get the first half of your flag!

Now that we know that this website isn't fully secured and we can manipulate authentication to get access to the admin page. Now its time to fire up burp suite.

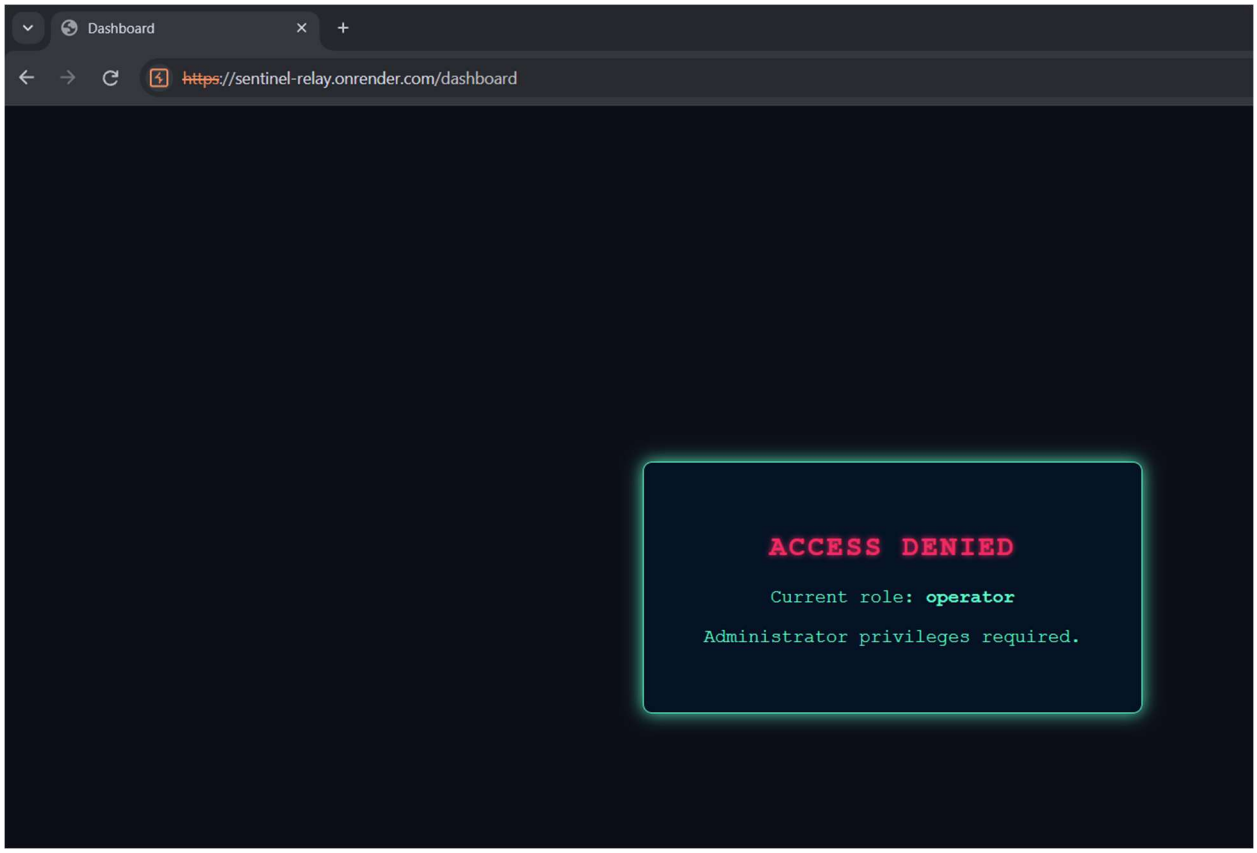
If you are using the free community version like me as soon as you fire it up you just need to hit next → start burp



Now, at the top ribbon, you want to select Proxy → ensure Intercept is off → open browser → paste in the ground station link and go.



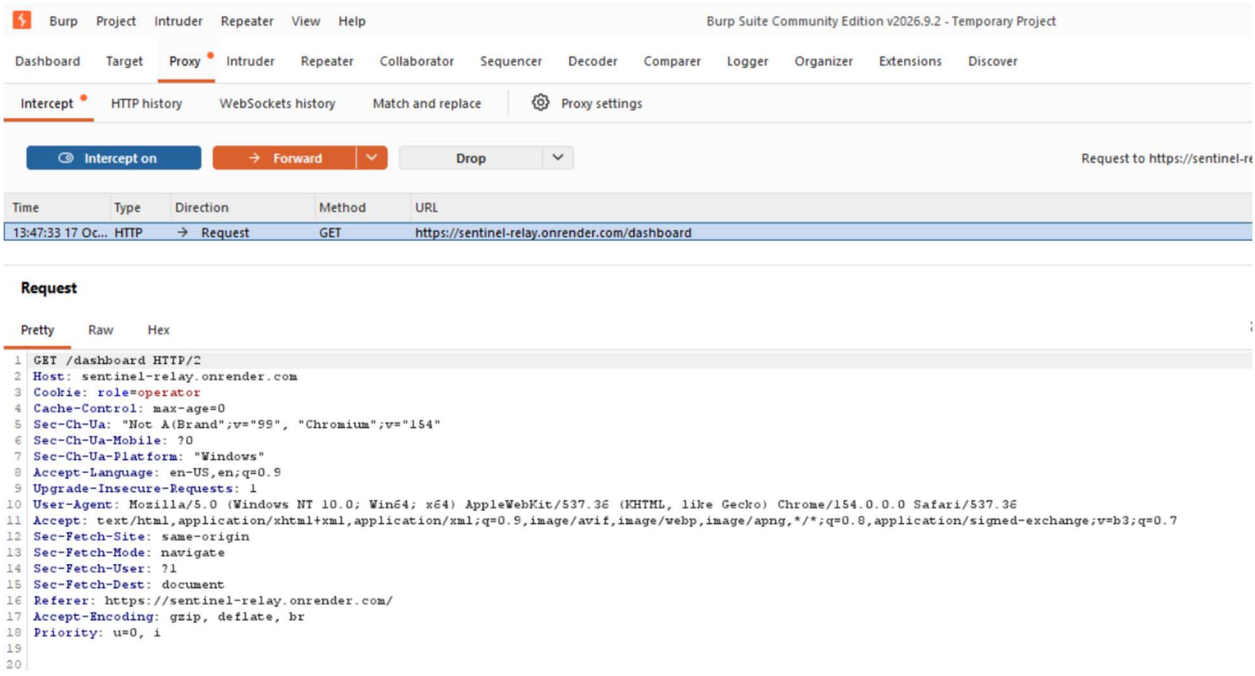
You can try the username and password you found through the first part of the flag, but you'll end up at the same failed login page.



Head back to Burp Suite and this time click **intercept on**.

Go back to the browser and just refresh the page, and then go back to Burp.

You'll see your new HTTP GET request with intercept activated.



This is where things get funny. Go down to line three and change the operator to admin.

```
Cookie: role=admin
```

Then hit forward, and Burp Suite will send that manipulated HTTP GET packet to the website, and you will get the second half of the flag!

From this challenge, you got a chance to play with a couple of new tools that could potentially be used for the real event! You learned how to do a vulnerability scan on a web application and how to manipulate HTTP packets!

Next, you'll stop the ongoing theft.